第二章 作品设计

一条公告进入系统之后，怎样成为可以回答问题、检查依赖的证据？本章沿着这条路径展开设计。重点不在于把模型放进多少环节，而在于确定每一环节的输入、谁有权改变结论，以及失败后如何继续。六层架构负责隔离变化，九个智能体承担明确职责，监测、富化和问答则共享同一套事实与来源记录。

2.1 系统总体架构设计

数据源接口变化快，漏洞事实需要长期保留，对外工具又必须稳定。如果把这三类变化放进一个服务，来源页面的一次改版就可能牵动检索和客户端。哨望因此按数据源、采集、知识、智能体编排、服务和接入划分六层，用公开的数据结构隔开来源适配与业务判断。



图 2.1 哨望总体架构

数据源层提供原始材料，来源的权威性在这一层被标注，但不会直接转化为最终结论。采集层以 Source Connector 插件适配各来源；增量轮询与历史回填采用固定入口，插件变化只影响材料取得方式。自有仓库的 webhook 由平台接收并验签，再触发立即轮询，不把对外事件入口交给第三方插件。

2.2.2 一条新公告的处理时序

第三方仓库并不允许任意监测方安装 webhook。对 vLLM、Ollama 等 P0 厂商来源，设计采用五分钟增量轮询；“实时”在这里指分钟级发现，并不意味着所有来源都提供推送。P1 来源按三十分钟轮询，把有限调用配额优先留给关键组件。

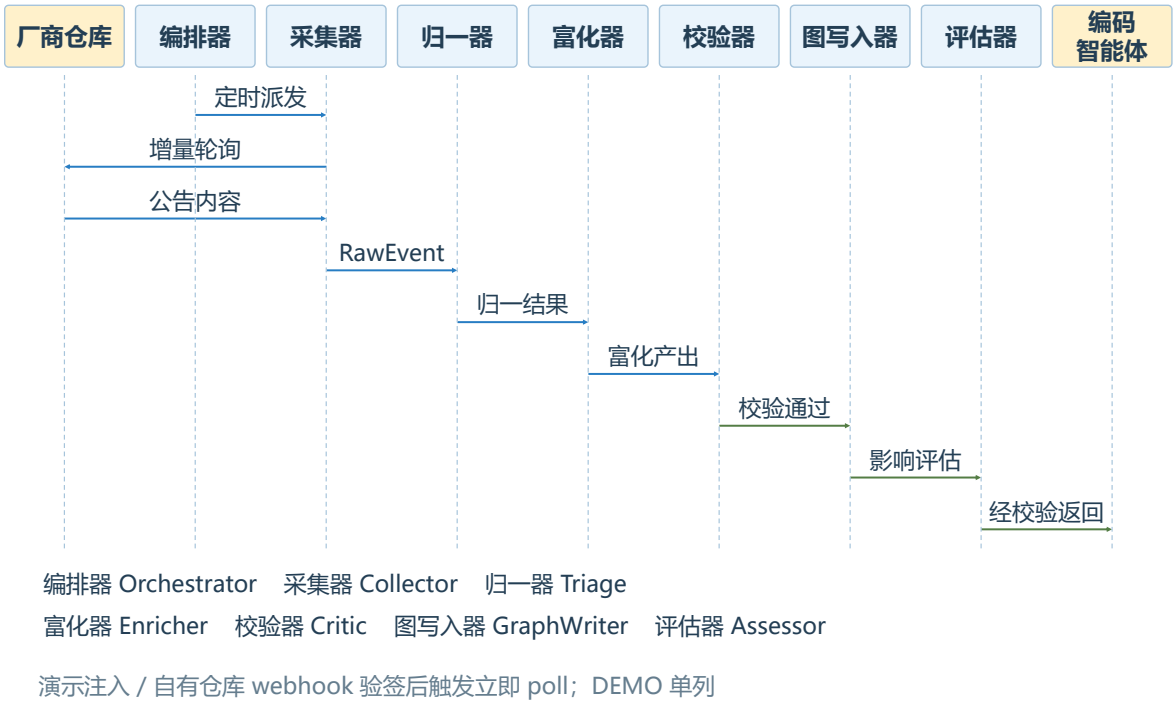


图 2.3 一条新公告从发布到可问答的时序

一次典型处理从 Orchestrator 派发轮询开始。Collector 取得公告，Triage 识别组件并生成归一记录，Enricher 补全画像，Critic 检查后才允许 GraphWriter 入库。新漏洞事件再触发 Assessor 判断风险和处置建议，对外产出仍需经过 Critic。时序中的每个箭头都对应数据或状态交接，而不是智能体之间的自由对话。

另一条路径用于自有仓库与答辩注入：平台验证事件签名后触发立即 poll，或由内部管理员调用演示入口。它与第三方轮询共用后续流水线，因此能演示归一、富化、校验的衔接；但它不能证明外部来源发现足够及时。演示数据带 DEMO 标记，统计默认排除。

厂商可能先发布修复版本，再补安全公告。Release 正文出现 security、CVE、GHSA、fix 等词时，会生成公告弱信号交 Triage。关键词命中只意味着需要复核，不等于已经确认漏洞，更不能直接触发高危告警。真正的时效结果为**【待测：漏洞类情报端到端时延 P95，目标值 ≤6 h】**。

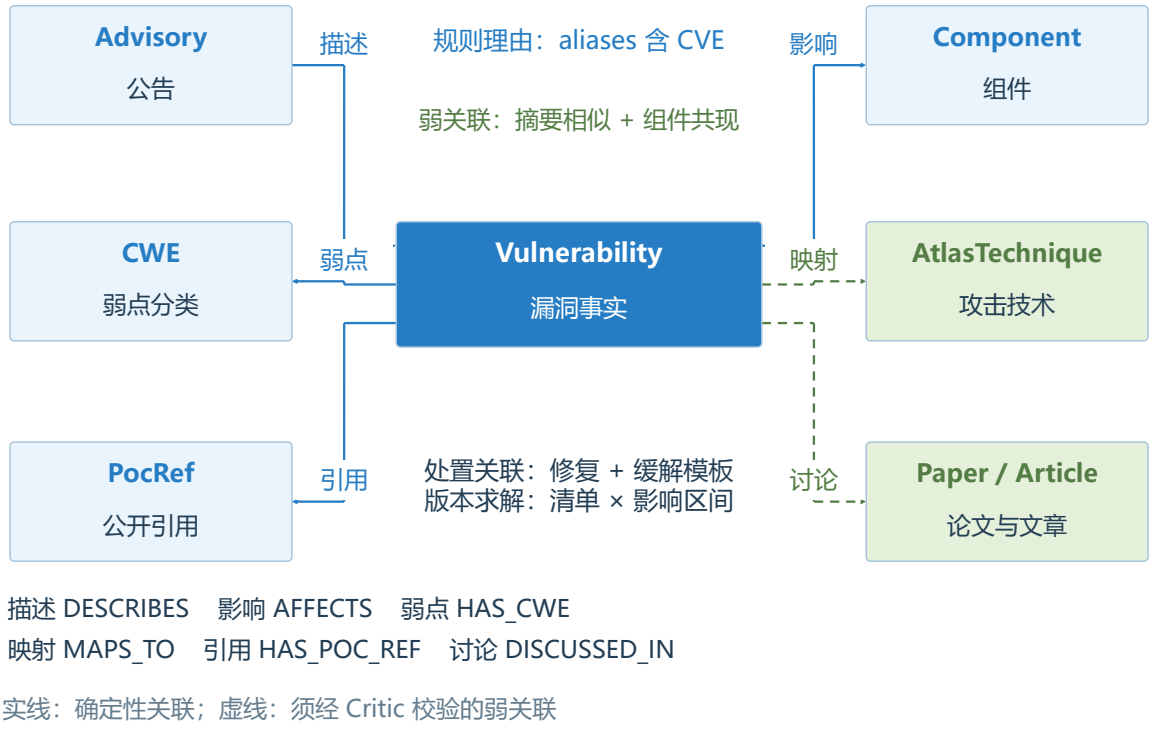


图 2.12 六类自动关联

公告通过 DESCRIBES 指向漏洞，漏洞通过 AFFECTS 指向组件，区间与修复信息随影响关系保存。MAPS_TO 指向 ATLAS 技术，DISCUSSED_IN 指向论文或文章；HAS_CWE、HAS_POC_REF、IN_CATEGORY 和 GOVERNED_BY 补充分类、引用与规范关系。处置建议由修复版本和缓解模板形成，版本求解则把用户清单与 AFFECTS 区间相交。

每条边必带 reason、confidence、method 和 created_by_agent。分析师点击关系时，应看到“公告的 aliases 包含该编号”这样的可核对理由，而不是只有“相关”二字。规则边可以直接回溯字段，模型边则显示候选依据和校验结论；可解释性由数据约束保证，再由界面呈现。

2.5.3 多源冲突的逐字段裁决

vLLM CVE-2025-32444 在 GHSA 与 NVD 中分别出现 10.0 和 9.8。选定一个主值便于排序，却不能抹掉另一方的向量与判断。冲突处理因此以字段为单位：同一漏洞的版本、评分和中文描述可以来自不同来源，每个胜出值各自携带 provenance。[3]

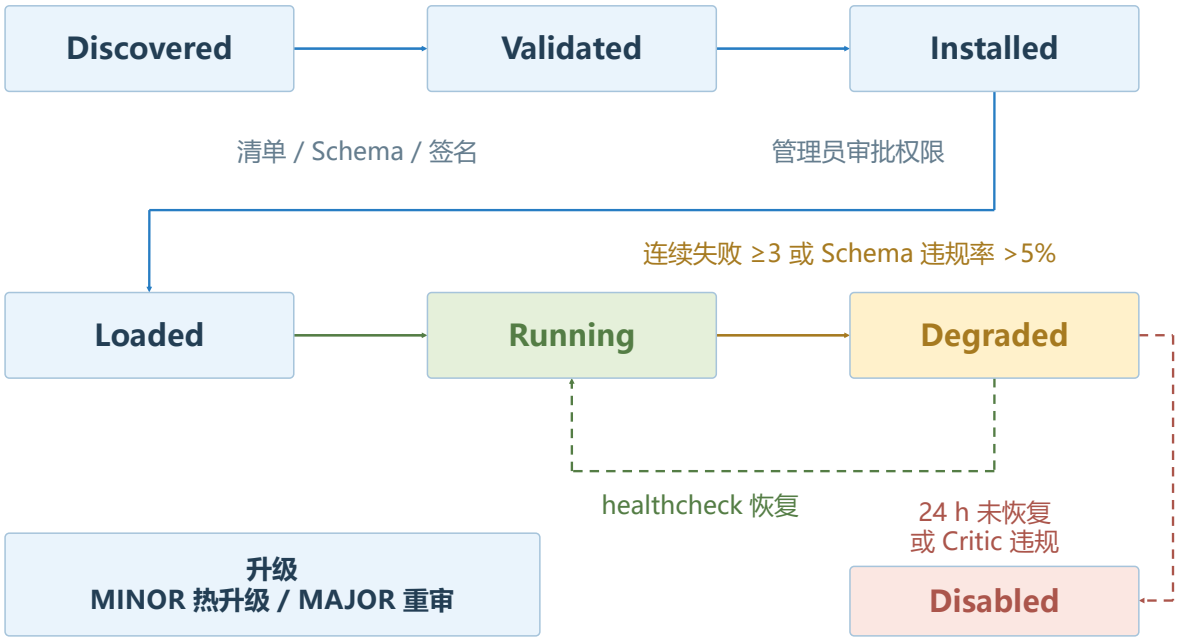


图 2.18 插件生命周期

8 类公开 Schema

common	normalized-intel	vulnerability	advisory
component	enrichment	relation	qa-answer

映射对象	OSV	STIX 2.1	CSAF 2.0
标识 / 别名	id / aliases	external_references	cve / ids
影响区间	ranges.events	software + relation	product_status
处置建议	FIX 引用	course-of-action	remediations
ATLAS	无原生项	attack-pattern	notes
关系与置信度	无原生项	relationship	无原生项
PoC 引用	EVIDENCE 链接	external_references	references

按映射表保留语义；没有原生字段的内容使用扩展，不能宣称天然无损

图 2.19 公开 Schema 与 OSV / STIX 2.1 / CSAF 2.0 的对应

三类扩展点分别接来源、补富化、组合只读工具。Source Connector 提供 poll 与 backfill；Enricher 接收只读漏洞并交出补丁和关系；Tool/Skill 组合已有查询。第三方插件没有写图权限，不能改其他插件负责的维度，输出还需经过 Schema 与合规检查。

部署中的秘密由环境和机密管理注入，不写在代码、配置样例或测试夹具里。CI 计划用 gitleaks 扫描，证据目录也要脱敏。Kubernetes 与 Helm 属于后续扩展方向，不能把可迁移的服务边界写成已经完成集群运行或容量验证。

3.1.2 数据模型与知识图谱

多源融合最容易丢掉的不是值，而是不同来源各自说过什么。因此公告 Advisory 与漏洞 Vulnerability 分开：公告保留来源、外部编号和原始链接，漏洞保存规范身份及裁决后的字段。发现错误时，可以回到具体公告核对，不必从一个混合描述中猜测来源。

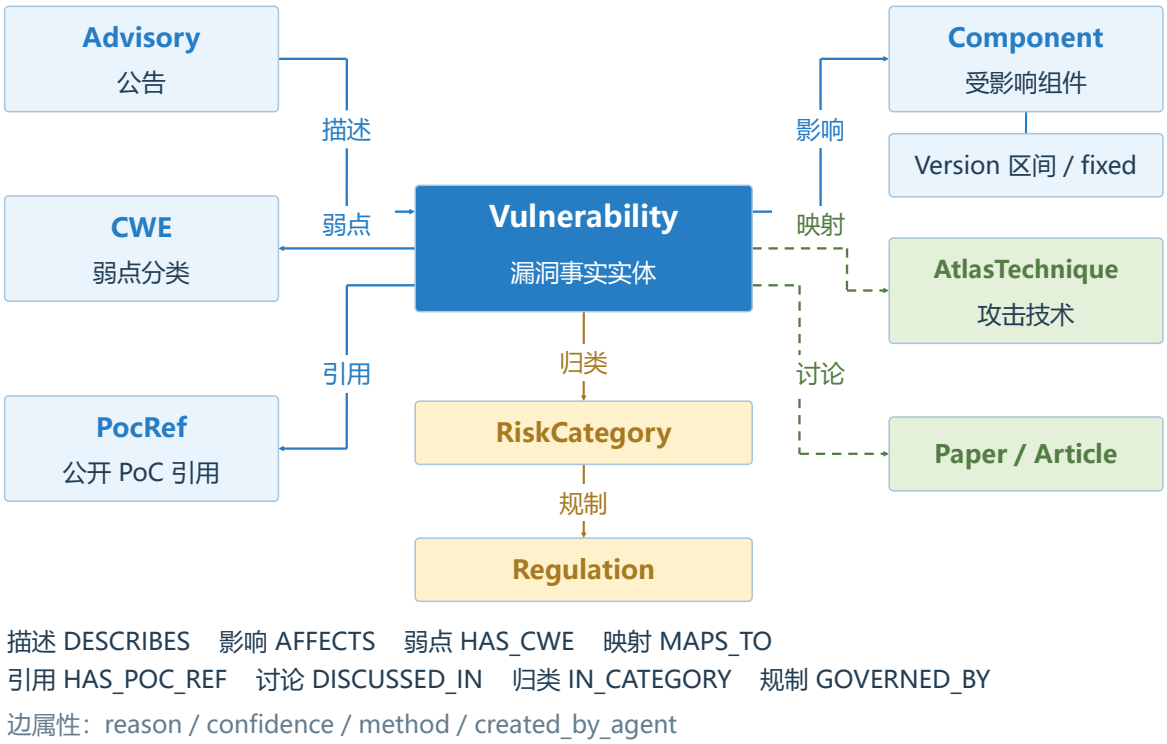


图 3.2 知识图谱数据模型

图模型包含漏洞、公告、组件、版本、CWE、ATLAS 技术、论文、文章、PoC 引用、法规和风险类别。AFFECTS 携带影响区间与修复信息，DESCRIBES 连接公告与漏洞，MAPS_TO 和 DISCUSSED_IN 支持技术与研究材料的扩展。理由、置信度、方法和创建角色与关系一起保存，使图上的路径可以落回证据。

PostgreSQL 保存归一情报、富化、任务、来源游标、冲突、审计及关系事实。pgvector 保存文本切片嵌入，OpenSearch 保存适合全文检索的标题、描述与编号；

测试类别	指标	设计目标	实测结果
富化准确	200 条金标集富化与关联准确率	≥95%	【待测：富化与关联准确率，目标值 ≥95%】
问答质量	100 题答案准确率	xx%	【待测：答案准确率，目标值 xx%】
问答质量	100 题引用正确率	xx%	【待测：引用正确率，目标值 xx%】
编排可靠	故障注入下的自愈成功率	xx%	【待测：自愈成功率，目标值 xx%】
接口性能	只读 MCP 工具同步调用时延 P95	xx s	【待测：MCP 只读工具时延 P95，目标值 xx s】



图 4.1 评测体系总览

监测 P95 不超过六小时、P0 采集 P95 不超过十分钟、稳定来源不少于七类、二百条金标集准确率不低于百分之九十五，均为设计目标。问答、自愈和接口性能中的 xx 是待冻结目标，不是零值或已达标状态。未定门槛需要在正式比较前补全，不能看到结果之后再调整目标。